

Two-Way Cryptographic Data Lifecycle: Ingress (Write/Encrypt) vs. Egress (Delegation/Decrypt)

End-to-End Security Architecture with ML-KEM-768 Key Encapsulation, Context-Bound AAD, $O(1)$ Cloud Delegation & Role-Gated Decryption

PATH A: DATA INGRESS PIPELINE (RECORD CREATION & ENCRYPTION)

STEP 1: CLINICAL INGRESS

Input: Patient Clinical Data

Patient Identity: $PID \in \text{UUID}$

- diagnosis: Acute Coronary
- symptoms: Chest Pain, SOB
- treatment: Percutaneous Angio
- prescription: Nitroglycerin 0.4mg
- doctor_notes: High Risk Follow-up

Granular Field Decomposition

STEP 2: KEY HIERARCHY & AAD

1. Ephemeral Root Session Key:

$K_{\text{session}} \leftarrow \text{AESGCM.generate_key}(256)$

2. HKDF-SHA256 Sub-Key Expansion:

$K_{\text{field}} = \text{HKDF}(K_{\text{session}}, \text{'pqc-field: ' || field || PID})$

3. Context-Bound AAD Construction:

$AAD = \text{'patient: ' || PID || ' : field: ' || field}$

Binds ciphertext to exact patient & field (Anti-Splicing)

STEP 3: HYBRID ENCRYPTION

Granular AES-256-GCM

Per-Field Encryption:

$(c_i, \nu_i, \tau_i) \leftarrow$

$\text{Enc}_{K_{\text{field}}}(V_i, AAD)$

12-Byte Random Nonce
16-Byte GHASH Tag
Payload Protected

Outputs: $\{c_1, c_2, \dots, c_m\}$

ML-KEM-768 Wrapping

NIST FIPS 203 Encaps:

$\text{Encaps}(pk_{\text{doc}}) \rightarrow$

(c_{kem}, ss)

$KEK \leftarrow \text{HKDF}(ss)$

$c_{\text{session_key}} \leftarrow \text{Enc}_{KEK}(K_{\text{session}})$

$|c_{\text{kem}}| = 1088 \text{ B}, |c_{\text{key}}| = 32 \text{ B}$

STEP 4: CIPHERTEXT TUPLE

Aggregated Record Payload for Database:

$C = (PID, c_{\text{kem}}, c_{\text{session_key}}, \nu_{\text{key}}, \{(c_i, \nu_i, \tau_i)\}_{i=1}^m)$

PID

UUID

c_kem

1088 B

c_session_key

32 B

{c_field, tau}

Granular

Zero Plaintext Exposure • Lattice Security Guaranteed

Ready for Cloud Ingestion without trusting Mediator

DB Ingestion
& Hash Chain

CENTRAL CLOUD MEDIATOR (HONEST-BUT-CURIOUS POSTGRESQL & AUDIT ENGINE)

1. Zero-Knowledge Relational Storage (PostgreSQL)

Stores tuple: $C = (PID, c_{\text{kem}}, c_{\text{session_key}}, \{c_{\text{field}}\})$

Threat Model: Cloud provider is Honest-but-Curious

Server CANNOT read clinical fields: Zero private key possession

KEY DELEGATION ENGINE

$O(1)$ Zero-Payload Access Delegation (Doctor A $\rightarrow$ Doctor B)

• Re-encapsulate ONLY 32-Byte Envelope: $\text{Encaps}(pk_{\text{docB}}) \rightarrow (c'_{\text{kem}}, c'_{\text{session_key}})$

• Clinical Payload {c_field} 100% UNTOUCHED on disk! (No lattice blowup)

Delegation Latency: 1.35 ms | Bandwidth Overhead: 0 Bytes Data Re-encryption

3. Tamper-Evident SHA-256 Hash Chaining

$\mathcal{H}_t = \text{SHA-256}(\mathcal{H}_{t-1} \parallel T_t \parallel \text{UID}_t \parallel \text{Action}_t \parallel \text{Res}_t)$

Detects any unauthorized DB edit, insertion or back-dating

Audit Verification: 1.45 ms (15,700x Faster than Ethereum Blockchain)

Access Granted: C

PATH B: DATA EGRESS PIPELINE (ACCESS REQUEST & IN-MEMORY DECRYPTION)

STEP 1: CLIENT DECAPSULATION

Authorized Practitioner Device (Doctor B)

1. Local RAM holds $sk_{\text{docB}} \in \{0, 1\}^{2400 \times 8}$

2. ML-KEM. Decaps($c'_{\text{kem}}, sk_{\text{docB}}$) $\rightarrow ss'$

3. Derive $KEK' \leftarrow \text{HKDF}(ss', \text{'pqc-ehr-v1'})$

4. Recover $K_{\text{session}} \leftarrow \text{Dec}_{KEK'}(c'_{\text{session_key}})$

Secure Isolated RAM Enclave

Zero Disk Plaintext Footprint • Side-Channel Protected

STEP 2: ROLE-BASED ACCESS GATING

Fine-Grained Role Permissions Check:

Attending Doctor

Full Access (Diagnosis, Rx, Symptoms, Vitals, Notes)

Nurse / Triage

Partial Access (Symptoms, Prescriptions, Vitals)

Pharmacist

Restricted Access (Prescription & Dosage Only)

Billing / Insurance

Zero Clinical Access (Metadata Only, Fields Masked)

Restricts sub-key derivation based strictly on verified role

STEP 3: GHASH & AAD VERIFY

Authenticated In-Memory Decryption:

1. Derive permitted $K_{\text{field}} \leftarrow \text{HKDF}(K_{\text{session}}, f_i)$

2. Reconstruct $AAD = \text{'patient: ' || PID || ' : field: ' || f_i}$

3. AES-GCM-Dec($c_i, \nu_i, K_{\text{field}}, AAD$)

Integrity Check: GHASH Tag Verification

Assert: $\tau_i = \text{GHASH}(c_i, AAD)$

Tag Mismatch $\rightarrow$ Immediate Tamper Abort!

STEP 4: PLAINTEXT VIEW

Decrypted In-Memory Clinical View:

Diagnosis: Acute Coronary

Doctor: Granted

Rx: Nitroglycerin 0.4mg

Doctor/Pharm: Granted

Symptoms: Chest Pain, SOB

Doctor/Nurse: Granted

Notes: Follow-up required

Doctor: Granted

Billing/Financial Audit

Clinical Masked [***]

Strict Avalanche Criterion (SAC) = 50.00% • Quantum Secure